Operación Trazabilidad · Libreta de auditoría

Exportación de actividad educativa · Versión del contenido auditoria_oficina_v2.1 · Reglas auditoria_reglas_v2.1

Alcance: conclusiones estructuradas sobre resúmenes del caso ficticio RedNova. No sustituye el informe del curso, la revisión humana, la base SQL ni los hallazgos académicos.

«Documentado» significa que se reunieron las fuentes y respuestas estructuradas exigidas para esta actividad educativa. Puede conservar una conclusión no concluyente; no aprueba hallazgos académicos, causalidad ni autoría.

AU-01 · Acceso y MFA Documentado

MFA (autenticación multifactor) exige factores distintos, como contraseña y código de una aplicación. VPN es una conexión privada a la red; API es una interfaz entre programas. Recertificar es revisar con el responsable qué cuentas y permisos siguen justificados.

La sesión de ext_ops_04 no identifica a una persona ni enlaza por sí sola la elevación o la lectura SQL. La política y sus excepciones siguen pendientes.

Conclusión estructurada

Se reporta una sesión sin MFA y cuentas sin recertificación reciente; faltan criterio aplicable y atribución personal.

Referencia: A01-OBSERVACION

Fuentes vinculadas

- E-01 · Usuarios y privilegios · versión auditoria_oficina_v2.1
- E-02 · Acceso VPN · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Estos datos identifican a la persona que entró y bastan para declarar un incumplimiento de política?

  Respuesta elegida: No; faltan atribución personal y criterio aplicable.

  Referencias: C01-ALCANCE · FALTAN_IDENTIDAD_Y_CRITERIO

  Fuentes: E-01 · Usuarios y privilegios · versión auditoria_oficina_v2.1; E-02 · Acceso VPN · versión auditoria_oficina_v2.1

Limitaciones

- L01-ATRIBUCION · La cuenta no equivale a la persona que la utilizó.
- L01-CRITERIO · No se aportó política aplicable ni su alcance.

Solicitudes y pendientes

- S01-POLITICA · Solicitar política de acceso y alcance aprobado.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

AU-02 · Lectura y transferencia Documentado

SQL es el lenguaje de consulta de datos; SELECT permite leerlos. Exfiltración significa salida no autorizada de información: el volumen de tráfico no identifica el contenido ni su autorización.

Este editor consulta resúmenes locales. Q-01–Q-12 se ejecutaron en SQL Server en I2/I3 sobre datos sintéticos v2 y se documentan en los anexos académicos. Esos resultados reproducen señales; no corroboran el incidente de forma independiente.

Conclusión estructurada

Se reportan lectura de 31,840 registros y transferencia de ~1.6 GB; contenido y vínculo no identificados.

Referencia: A02-TRANSFERENCIA

Fuentes vinculadas

- DECL-05 · Declaración de Seguridad Informática · versión auditoria_oficina_v2.1
- E-03 · Bitácora SQL Server · versión auditoria_oficina_v2.1
- E-04 · Tráfico cloud · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Estos registros identifican el contenido transferido y lo conectan con la lectura SQL?

  Respuesta elegida: No; falta correlación entre los eventos y el contenido.

  Referencias: C02-CONTENIDO · SIN_VINCULO_NI_CONTENIDO

  Fuentes: DECL-05 · Declaración de Seguridad Informática · versión auditoria_oficina_v2.1; E-03 · Bitácora SQL Server · versión auditoria_oficina_v2.1; E-04 · Tráfico cloud · versión auditoria_oficina_v2.1

Limitaciones

- L02-CONTENIDO · El contenido transferido está sin identificar.
- L02-VINCULO · No se demuestra que lo leído sea lo transferido.
- L02-ATRIBUCION · La sesión conocida no atribuye todas las operaciones a la misma persona o cuenta.

Solicitudes y pendientes

- S02-FLUJO · Solicitar registros de flujo, destino y proceso de origen correlacionables.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

AU-03 · Órdenes, integridad y despliegue Documentado

CRM es el sistema de gestión de clientes y órdenes. Conciliar significa comparar historial de órdenes y facturación para identificar y explicar diferencias. BD significa base de datos.

El expediente reporta 216 órdenes. Los 144 cambios de monto y 72 de estado de Q-07 son diseño sintético, sin cuenta, sesión ni vía conocidas. Los diez pares candidatos de Q-08 no prueban doble cobro. La conciliación del incidente sigue pendiente.

Conclusión estructurada

Los cambios reportados preceden al despliegue; integridad, aprobación formal, autoría y relación causal siguen sin demostrarse.

Referencia: A03-PENDIENTES

Fuentes vinculadas

- EVT-06 · Modificación de órdenes · versión auditoria_oficina_v2.1
- EVT-07 · Despliegue de integración · versión auditoria_oficina_v2.1
- E-06 · Ticket de cambios · versión auditoria_oficina_v2.1
- DECL-03 · Declaración de Desarrollo · versión auditoria_oficina_v2.1
- DECL-04 · Declaración de Administrador de BD · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Qué orden muestran las horas reportadas de cambios y despliegue?

  Respuesta elegida: Los cambios ocurrieron antes del despliegue.

  Referencias: C03-ORDEN · ORDENES_ANTES

  Fuentes: EVT-06 · Modificación de órdenes · versión auditoria_oficina_v2.1; EVT-07 · Despliegue de integración · versión auditoria_oficina_v2.1

- **Pregunta:** ¿Las declaraciones bastan para dar por verificadas la integridad y la aprobación formal?

  Respuesta elegida: No; faltan conciliación concluida y aprobación formal.

  Referencias: C03-SOPORTES · FALTAN_CONCILIACION_Y_APROBACION

  Fuentes: EVT-06 · Modificación de órdenes · versión auditoria_oficina_v2.1; E-06 · Ticket de cambios · versión auditoria_oficina_v2.1; DECL-03 · Declaración de Desarrollo · versión auditoria_oficina_v2.1; DECL-04 · Declaración de Administrador de BD · versión auditoria_oficina_v2.1

Limitaciones

- L03-CAUSA · El orden de las horas no demuestra que el despliegue causara el incidente ni que fuera ajeno a él.

- L03-INTEGRIDAD · La conciliación no ha concluido.
- L03-ATRIBUCION · Los cambios no tienen atribución probada.
- L03-APROBACION · La falta de aprobación documentada no prueba que jamás se autorizó.

Solicitudes y pendientes

- S03-CONCILIACION · Solicitar historial y conciliación reproducible de órdenes y facturación.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

AU-04 · Alerta y atención Documentado

SIEM es el sistema que reúne registros y genera alertas de seguridad. La alerta reportada de las 03:18 no incluye asignación, primera acción ni cierre documentados.

Los 61 minutos entre sesión y alerta y los 24 hasta la caída son diferencias de horas reportadas. No prueban tiempo de detección, inacción ni pérdida de registros; los relojes no están verificados.

Conclusión estructurada

Entre el acceso reportado y la alerta hay 61 minutos; no se conoce la trazabilidad completa de atención.

Referencia: A04-INTERVALO

Fuentes vinculadas

- EVT-02 · Sesión remota sin MFA · versión auditoria_oficina_v2.1
- EVT-08 · Alerta crítica de seguridad · versión auditoria_oficina_v2.1
- E-07 · Alertas de seguridad · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** El sistema calcula 61 minutos entre 02:17 y 03:18. ¿Qué significa ese intervalo?

  Respuesta elegida: Es el intervalo entre dos registros preliminares.

  Referencias: C04-INTERVALO · INTERVALO_ENTRE_REGISTROS

  Fuentes: EVT-02 · Sesión remota sin MFA · versión auditoria_oficina_v2.1; EVT-08 · Alerta crítica de seguridad · versión auditoria_oficina_v2.1; E-07 · Alertas de seguridad · versión auditoria_oficina_v2.1

Limitaciones

- L04-INICIO · No se conoce el inicio real del ataque.
- L04-ATENCION · Sin cierre documentado no equivale a ausencia de acción.
- L04-OBJETIVO · No hay objetivo aplicable de detección o atención aportado.

Solicitudes y pendientes

- S04-ATENCION · Solicitar asignación, primera acción, escalamiento y cierre.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado

Plazo propuesto: No registrado
Verificación: No registrada

AU-05 · Respaldo y recuperación Documentado

RTO es el tiempo objetivo para restablecer el servicio. RPO es la pérdida de datos tolerable expresada en tiempo. BIA es el análisis del impacto de una interrupción en el negocio.

Los 315/355 minutos hasta consulta/escritura describen retorno reportado; no calculan el RPO ni prueban cumplimiento. En este incidente faltan el informe que identifique el respaldo usado y las pruebas de datos recuperados. El registro de julio del laboratorio es ficticio; no se ejecutó una restauración.

Conclusión estructurada

Hay respaldos programados y recuperación por etapas reportada; no se demuestra restauración validada ni cumplimiento de RTO/RPO.

Referencia: A05-NO_VERIFICADA

Fuentes vinculadas

- E-08 · Respaldos · versión auditoria_oficina_v2.1
- EVT-09 · Caída del CRM · versión auditoria_oficina_v2.1
- EVT-11 · CRM disponible para consulta · versión auditoria_oficina_v2.1
- EVT-12 · Escritura restablecida · versión auditoria_oficina_v2.1
- DECL-07 · Declaración de Continuidad · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** Los intervalos son 315 minutos hasta solo consulta y 355 hasta escritura. ¿Esto demuestra una restauración validada dentro de los objetivos del negocio?

  Respuesta elegida: No; faltan prueba de restauración y objetivos aplicables.

  Referencias: C05-RECUPERACION · FALTAN_PRUEBA_Y_OBJETIVOS

  Fuentes: E-08 · Respaldos · versión auditoria_oficina_v2.1; EVT-09 · Caída del CRM · versión auditoria_oficina_v2.1; EVT-11 · CRM disponible para consulta · versión auditoria_oficina_v2.1; EVT-12 · Escritura restablecida · versión auditoria_oficina_v2.1; DECL-07 · Declaración de Continuidad · versión auditoria_oficina_v2.1

Limitaciones

- L05-EJECUCION · La programación no acredita una ejecución exitosa.
- L05-RESTAURACION · Faltan respaldo usado, punto recuperable e integridad verificada.
- L05-OBJETIVOS · Faltan RTO/RPO aplicables.

Solicitudes y pendientes

- S05-PRUEBA · Solicitar informe de restauración, respaldo utilizado, validación y conciliación.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

AU-06 · Custodia y tiempo Documentado

Metadatos son datos sobre un archivo, como su ruta y procedencia. SHA-256 es una huella calculada de sus bytes. Compararla con una referencia previamente registrada permite detectar cambios; no demuestra verdad ni completitud. Hay que conservar el origen de esa referencia.

Aquí se consultan metadatos del resumen, sin leer archivos ni calcular hashes. Los hashes de anexos sintéticos no autentican originales del incidente. AU-06 no sustituye PT-25: los permisos efectivos se comprobaron solo en laboratorio. B1-1/B1-2 siguen no concluyentes y pendientes de revisión humana y de P3.

Conclusión estructurada

La procedencia académica está identificada; custodia de extracciones y sincronización de fuentes no están acreditadas.

Referencia: A06-LIMITACION

Fuentes vinculadas

- META-CUSTODIA · Inventario de archivos y custodia · versión auditoria_oficina_v2.1
- META-TIEMPO · Relojes y horas originales · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Puede tratarse este resumen como una extracción con custodia acreditada?

  Respuesta elegida: No; faltan originales, método, custodio y hashes.

  Referencias: C06-CUSTODIA · CUSTODIA_NO_ACREDITADA

  Fuentes: META-CUSTODIA · Inventario de archivos y custodia · versión auditoria_oficina_v2.1

- **Pregunta:** ¿Qué muestra la comparación entre hora reportada, original, desfase y verificación?

  Respuesta elegida: La sincronización de las fuentes no está verificada.

  Referencias: C06-RELOJ · SINCRONIZACION_NO_VERIFICADA

  Fuentes: META-TIEMPO · Relojes y horas originales · versión auditoria_oficina_v2.1

Limitaciones

- L06-RESUMEN · Un resumen no equivale a una extracción.
- L06-HASH · Comparar el SHA-256 de un archivo con una referencia previamente registrada permite detectar cambios; no demuestra verdad ni completitud. Debe conservarse el origen de la referencia.

- L06-TIEMPO · Un desfase desconocido no es cero verificado.

Solicitudes y pendientes

- S06-EXTRACCIONES · Solicitar originales preservados, método, custodio y hashes.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

Límites generales del expediente de referencia

- Persona que usó ext_ops_04 y relación con la solicitud del día 12.
- Contenido transferido y conexión probada entre la lectura SQL y el flujo externo.
- Identidad y sesión que explican los cambios de órdenes; conciliación e integridad final.
- Relación causal del despliegue con el incidente.
- Hora de primera acción ante la alerta y respuesta completa ejecutada.
- Horas originales, fiabilidad y desfases de cada fuente.
- Respaldo exacto usado, punto recuperable y cumplimiento de objetivos de negocio.
- Cadena de custodia completa de extracciones no aportadas.
- Escala y calibración del puntaje de IA.

Generado localmente, sin conexión a SQL Server ni servicios remotos. La hora de exportación no es una hora del incidente.

